E-tiGo — Data Security Measures

Prepared by: Engineering Lead
Date: 5 November 2026
Purpose: Answer to question 7 (data security) for the privacy policy. Covers the Passenger App, Driver App, Admin Dashboard and backend.

Summary

Personal data is protected at every stage: it is encrypted while it travels between the apps and our servers, sensitive records are encrypted or hashed where they are stored, and each person (passenger, driver or staff member) can only see the data their role needs. Card details never touch our servers; they are held by our licensed payment providers. Staff actions are recorded in an audit trail, and every change to the system is tested automatically before release.

1. Encryption

- **In transit:** All traffic between the Passenger App, Driver App, Admin Dashboard and our servers uses HTTPS (TLS). Live trip and location updates use secure WebSockets (WSS).
- **SSL pinning:** The mobile apps use SSL (certificate) pinning, so they only talk to E-tiGo's genuine servers. This blocks 'man-in-the-middle' interception, even on public Wi-Fi.
- **At rest:** Especially sensitive records are encrypted in the database with AES-256: driver ID numbers (NIN, driver's licence, and plate numbers submitted for verification), the personal details and results of identity verification (KYC), and SOS emergency incident data (vehicle details and telemetry).
- **Passwords and codes:** Staff passwords are stored only as one-way hashes (bcrypt), and login codes (OTPs) are stored hashed too, so they cannot be read back even by us. Trip PINs are stored hashed as well; a readable copy is kept for at most six hours so the rider can see their PIN, and it is deleted as soon as the driver enters it.

2. Secure data storage

- **Payment cards:** We never store full card numbers or CVVs. Cards are handled by Paystack (PCI-DSS certified). We keep only a payment token, the card brand, the last four digits and the expiry date, to show the card in the app.
- **Bank accounts:** Driver payout account numbers are masked (only the last four digits shown) wherever they are displayed.
- **Documents and photos:** Driver documents, vehicle papers, dispute evidence and other uploads are kept in private cloud storage (Cloudinary), not on the phone. They have no public address: each file opens only through our servers, for a signed-in person it was shared with (for example the driver who uploaded a document, or the staff reviewing it). A copied link does not work for anyone else, and it stops working once that person's sign-in ends. Profile photos are the only public images.
- **Secrets:** API keys and passwords for our services are kept in protected server configuration, never in the app code.
- **Database: [TO CONFIRM: the production database accepts connections only from our application servers, not the public internet.]**

3. Access controls

- **Role-based staff access:** The Admin Dashboard has separate roles: Super Admin, Operations, Safety Operator, Support, Support Lead and Finance. Each role sees only the screens and data it needs (for

example, only Finance can freeze a wallet, and only Safety Operators receive live SOS emergency alerts).

- **Invitation-only staff accounts:** Staff cannot sign up themselves; an administrator must invite them.
- **Passengers and drivers:** Users can only see their own trips, wallet, payment methods and history. Drivers cannot go online or receive rides until their documents and identity are approved.
- **Live trip data:** Real-time trip channels are private: only the passenger and driver on that trip (and authorised staff) can join them.
- **Rate limiting:** Sensitive actions (login, OTP, payments, wallet top-ups, reports) are limited per minute to stop abuse and automated attacks.

4. Authentication

- **Passengers and drivers:** Sign in with a one-time code (OTP) sent by SMS to their phone number, or with Google/Apple sign-in. OTPs are 6 digits, expire after 5 minutes, can be requested once a minute, and lock after 5 wrong attempts.
- **Staff:** Email and password, with secure password reset. A second sign-in step is built and ready: after their password, staff must also enter a 6-digit code sent to their email. The code expires after 10 minutes, works once, and the sign-in is cancelled after 5 wrong codes. It will be switched on when the Admin Dashboard screen for it is released.
- **Sessions:** Each login gets a unique access token. Staff sessions expire after 8 hours; app sessions after 30 days. Logging out, or asking to delete an account, revokes the token straight away.
- **Trip PIN:** A 4-digit PIN confirms the right passenger is in the right car before a trip starts (limited to 3 attempts).
- **Payment and identity providers:** Messages from Paystack, Flutterwave and our identity-verification provider are checked with a cryptographic signature, so fake payment confirmations are rejected.

5. GPS / location data protection

- **When it is collected:** Driver location is collected only while the driver is online or on a trip. Passenger location is used for pickup, drop-off and live trip tracking.
- **How it is sent:** Location updates travel over an encrypted connection, and the driver must be signed in (verified token) before any location is accepted.
- **How long the live position is kept:** A driver's live position is held in short-term memory and expires automatically within 5 minutes once updates stop. The trip route is saved with the trip record for fare calculation, receipts, disputes and safety investigations.
- **Sharing:** A passenger can choose to share a live trip link (for example with family). The link uses a long random code and works only for that trip. For trips booked for someone else, the booker chooses who receives tracking and the PIN.

6. Audit logs

- **Staff actions:** Important admin actions (driver approvals, refunds, wallet changes, sanctions, settings changes and so on) are recorded with who did it, what changed (before and after), when, and from which IP address and device.
- **Trip history:** Every trip status change is recorded, as are all SOS emergency events.
- **Money:** Wallet and payment activity is kept in a double-entry ledger with automatic integrity checks.
- **Request logs:** Server access logs are kept in daily files and rotated automatically.

7. Backup and recovery

- **Database backups: [TO CONFIRM: backup schedule, retention period and where backups are kept, for example daily automated backups kept for N days.]**
- **Safe releases:** Each new version is installed alongside the current one. If anything fails during the update, the previous working version stays live, so users are not affected.
- **Payment records:** Payment and payout records also exist with our payment providers (Paystack, Flutterwave), so they can be reconciled independently.

8. Security testing

- **Automated tests:** An automated test suite runs on every code change before it can be deployed. It includes checks that users and staff cannot reach data outside their role.
- **Code review:** Changes are reviewed before they are merged into the main codebase.
- **Test environment:** New features are tested on a separate staging environment, with test payment keys, before release.
- **Penetration testing: [TO CONFIRM: whether an independent penetration test is planned before launch.]**

9. Data retention and deletion

- **Account deletion:** Passengers and drivers can ask to delete their account from the app. They are signed out on every device straight away, and the account is deleted after a 30-day grace period; signing in again during that time cancels the request. Deletion removes their sign-in details, saved places, saved cards, social logins, notification settings and profile photo. An account with no trips is erased completely. For an account with trips, the name, phone number, email and password are erased, and the trip and payment records that the law and accounting require us to keep are retained without them. A request can't be made during an active trip, or while money is still owed either way (a wallet balance to refund, driver earnings not yet paid out, or an outstanding balance) or an E-tiGo car agreement is active, so these can be settled first.
- **In-app notifications:** Deleted automatically after 90 days.

10. Trusted service providers

We share data only with providers needed to run the service:

- **Payments:** Paystack and Flutterwave
- **Identity verification (drivers):** QoreID
- **SMS / OTP:** Sendchamp
- **Email:** Resend
- **Push notifications:** Google Firebase
- **Maps and addresses:** Google Maps
- **File and image storage:** Cloudinary